

Controls and compliance checklist

This audit was completed by Said Al Harthy

Controls assessment checklist

Yes	No	Control
	☒	Least Privilege
	☒	Disaster recovery plans
☒		Password policies
	☒	Separation of duties
☒		Firewall
	☒	Intrusion detection system (IDS)
	☒	Backups
☒		Antivirus software
☒		Manual monitoring, maintenance, and intervention for legacy systems
	☒	Encryption
	☒	Password management system
☒		Locks (offices, storefront, warehouse)
☒		Closed-circuit television (CCTV) surveillance
☒		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
		● Only authorized users have access to customers' credit card information. ● Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. ● Implement data encryption procedures to better secure credit card transaction touchpoints and data. ● Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
		● E.U. customers' data is kept private/secured.
●		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	●	Ensure data is properly classified and inventoried.
●		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
		● User access policies are established. ● Sensitive data (PII/SPII) is confidential/private.
●		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
●		Data is available to individuals authorized to access it.

Based on my audit of Botium Toys, it's pretty clear we've got some significant security work ahead of us. The current setup leaves us quite vulnerable. To protect Botium Toys and ensure we're compliant with regulations like PCI DSS and GDPR, here are my key recommendations for the IT manager:

- **Tighten Up User Access (Least Privilege & Separation of Duties):** Right now, pretty much everyone has access to everything, including sensitive customer data. We urgently need to implement "least privilege" (giving people only the access they need for their job) and "separation of duties" (splitting critical tasks among different people). This is crucial to prevent internal misuse or accidental breaches, and it's a big step towards PCI DSS and SOC compliance.
- **Encrypt Everything Sensitive (Especially Credit Cards!):** Our customer credit card data isn't encrypted when it's stored or processed, which is a major red flag for PCI DSS. We need to get encryption in place for all payment information to keep it confidential and secure this could eventually leak SPII.
- **Get Serious About Backups and Disaster Recovery:** We currently don't have any formal disaster recovery plans or proper backups of our critical data. This is super risky! If something goes wrong (like a system failure or a ransomware attack), we could lose everything. We need to create and regularly test plans for how we'd recover our systems and data, and set up reliable backup solutions.
- **Fix Our Password Problem:** Our current password policy is too weak, and we don't have a centralized system to manage them. This makes us an easy target for attacks and causes productivity issues. We need to implement a strong password policy (think complex requirements, not just 8 characters!) and get a proper password management system in place.
- **Install an Intrusion Detection System (IDS):** We currently don't have an IDS, which means we're missing a key tool for spotting suspicious activity on our network. Getting an IDS would greatly improve our ability to detect potential threats early.
- **Prioritize PCI DSS & GDPR Compliance:** Many of the issues I found directly impact our compliance with these regulations. We need to focus on closing these gaps quickly to avoid significant fines and maintain trust with our customers, especially those in the E.U.